

Proyecto de SGSI: Instituto Nacional de Estándares y Tecnología (NIST)

Paso 1: Selección de la Organización

He seleccionado al **NIST (National Institute of Standards and Technology)** porque es una organización pública clave que desarrolla los estándares de seguridad que el resto del mundo sigue. Manejan datos de investigaciones muy importantes y sistemas de tiempo nacional. Al ser una organización pública, tienen mucha información disponible que facilita este estudio.

Paso 2: Definición del Alcance

En este paso, defino qué vamos a proteger para no intentar abarcar toda la agencia de una vez.

2.1 Inventario de Activos (Lo que vamos a cuidar)

He identificado los activos más importantes y los he clasificado según su importancia

Activo	Tipo	Importancia
Base de Datos Científica	Datos	Crítico
Servidores	Hardware	Crítico
Red de Laboratorios	Red	Alto
Computadoras de Investigadores	Hardware	Medio
Registros de Empleados	Datos	Medio

2.2 Ubicaciones y Límite

- **Físico:** El SGSI cubrirá el Centro de Datos principal en Gaithersburg y los laboratorios de Boulder.
- **Lógico:** Incluiremos la red interna (Intranet), el portal web oficial y los sistemas de almacenamiento en la nube.

2.3 Personas Involucradas

- **Directivos:** Dan el permiso y el dinero para el proyecto.
- **Equipo de TI:** Instalan y configuran las herramientas de seguridad.
- **Usuarios (Científicos y empleados):** Deben seguir las reglas de seguridad.

Paso 3: Evaluación de Riesgos

Aquí analizo que cosas malas podrían pasar y que tan probable es que ocurran.

3.1 Amenazas y Vulnerabilidades

He detectado estos problemas principales usando la tabla de ejemplo de la USP:

Amenaza	¿Por qué puede pasar? (Vulnerabilidad)	Impacto si ocurre	Probabilidad
Ataque de Phishing	Falta de capacitación a empleados.	Robo de contraseñas.	Alta
Ransomware	Falta de copias de seguridad al día.	Pérdida de datos.	Media
Falla de Servidor	Equipos viejos o sin mantenimiento.	El sistema se cae.	Baja

3.2 Clasificación del Riesgo

Sumando el impacto y la probabilidad, mi prioridad será atacar primero el **Phishing** y el **Ransomware** porque pueden paralizar al NIST.

Paso 4: Selección de controles

Ahora elijo las reglas para bajar los riesgos.

Riesgo	Control (Basado en ISO 27001 / NIST CSF)	¿Qué vamos a hacer?
Acceso no autorizado	Control de Acceso	Usar doble factor de autenticación (MFA).
Pérdida de Datos	Copias de Seguridad	Hacer backups automáticos cada noche.
Ataques de Red	Firewalls y Antivirus.	Instalar un Firewall potente en la entrada.

Paso 5: Políticas y Procedimientos

Estas son las reglas escritas que todos deben seguir

5.1 Reglas para las Contraseñas

- Las contraseñas deben tener letras, números y símbolos.
- No se pueden compartir con nadie.
- Se cambiarán obligatoriamente cada 90 días.

5.2 Qué hacer ante un incidente?

1. **Reportar:** Si ves algo raro, avisa a soporte técnico rápido.
2. **Aislar:** Desconectamos la computadora infectada para que no contagie a otras.
3. **Limpiar:** Borramos el virus y recuperamos los archivos desde el backup.

Paso 6: Manual del SGSI

Este es el resumen de todo nuestro plan para el NIST.

- **Objetivo:** Queremos que la información científica nunca se pierda y que siempre esté segura
- **Cómo mediremos el éxito (KPIs):**
 - Que no haya más de 1 virus al mes.
 - Que todos los empleados pasen el curso de seguridad.
 - Que las copias de seguridad funcionen siempre.